Deber: Web Defense & Privacy Compliance

1. Mapeo de OWASP y CWE:

Categoría OWASP	CWE Específico	CVE Reciente	Resumen de Impacto CVE
A01:2021 - Pérdida de Control de Acceso	**CWE-22:** Limitación inadecuada de un nombre de ruta a un directorio restringido (Path Traversal)	**CVE-2025-66278**	Permite a un atacante remoto autenticado explotar una falla en el sistema de archivos para leer contenidos de archivos inesperados o datos subyacentes del servidor. Esto rompe el aislamiento de los directorios restringidos, comprometiendo de forma crítica la confidencialidad de la información.
A03:2021 – Inyección de datos	**CWE-89:** Neutralización inadecuada de elementos especiales en un comando SQL (SQL Injection)	**CVE-2026-2584**	Un atacante remoto y no autenticado puede enviar consultas manipuladas a través de una interfaz de inicio de sesión vulnerable para evadir los controles. Esta explotación de baja complejidad facilita un compromiso total de los datos, permitiendo extraer y alterar las configuraciones críticas alojadas en la base de datos.
A07:2021 - Fallos de Identificación y Autenticación	**CWE-798:** Uso de credenciales codificadas de forma rígida (Hard-coded Credentials)	**CVE-2025-1393**	La aplicación contiene secretos administrativos estáticos incrustados directamente en el código base, los cuales no pueden ser modificados de forma rutinaria por los usuarios. Al descubrir estas credenciales, los atacantes logran evadir completamente la autenticación de red y asumen el control total del sistema sin necesidad de interacción previa.

2. El contexto ecuatoriano:

Identificar los ocho derechos del titular de los datos mencionados en la ley.

El Capítulo III de la LOPDP de Ecuador establece los derechos fundamentales que permiten a los ciudadanos controlar su información personal. Estos son los ocho derechos principales del titular:

1. **Derecho a la información (Art. 12):** El titular tiene derecho a ser informado de manera clara, transparente y comprensible sobre cómo, por qué y para qué se están recopilando y tratando sus datos personales.

2. **Derecho de acceso (Art. 13):** Permite al titular conocer y obtener gratuitamente acceso a todos sus datos personales que se encuentran bajo el tratamiento de un tercero.
3. **Derecho de rectificación y actualización (Art. 14):** Otorga la capacidad de solicitar la corrección de datos personales que sean inexactos, incompletos, desactualizados o falsos.
4. **Derecho de eliminación (Art. 15):** También conocido como el "derecho al olvido", permite exigir la supresión de los datos personales cuando ya no sean necesarios para los fines recogidos, se haya retirado el consentimiento o el tratamiento sea ilícito.
5. **Derecho de oposición (Art. 16):** El titular puede negarse a que sus datos sean tratados para fines específicos, como marketing directo o cuando afecte sus derechos fundamentales.
6. **Derecho a la portabilidad (Art. 17):** Permite al usuario recibir sus datos personales en un formato estructurado, de uso común y lectura mecánica, y transferirlos a otro responsable del tratamiento sin impedimentos.
7. **Derecho a la suspensión del tratamiento (Art. 19):** Otorga la facultad de solicitar que se detenga temporalmente el procesamiento de los datos mientras se resuelve una impugnación sobre la exactitud o la legalidad de estos.
8. **Derecho a no ser objeto de decisiones automatizadas (Art. 20):** Las personas tienen derecho a no ser objeto de decisiones tomadas exclusiva (o parcialmente, en determinados contextos) mediante el procesamiento automatizado, incluida la elaboración de perfiles, cuando dichas decisiones les afecten significativamente.

Explique brevemente cómo la Superintendencia de Protección de Datos (el organismo regulador) aplica estos derechos en comparación con el RGPD de la UE.

La Superintendencia de Protección de Datos Personales (SPDP) es el órgano rector en Ecuador encargado de hacer cumplir la LOPDP, operando como una autoridad única y centralizada. Esto contrasta con el modelo descentralizado de la Unión Europea bajo el GDPR, donde cada Estado miembro tiene su propia autoridad nacional, pero todas operan coordinadas por el Comité Europeo de Protección de Datos (EDPB). A nivel procedimental, ambos sistemas comparten el enfoque de "responsabilidad proactiva", exigiendo a las organizaciones demostrar técnicamente su cumplimiento y otorgando a las autoridades el poder de realizar auditorías, gestionar denuncias ciudadanas e imponer ceses de tratamiento. La diferencia más notoria radica en los límites de sus regímenes sancionatorios: mientras el GDPR contempla multas devastadoras de hasta 20 millones de euros o

el 4% de la facturación global anual de una empresa, la LOPDP ecuatoriana maneja un tope del 0.7% al 1% del volumen de negocio total para las infracciones más graves.

En términos de aplicación práctica y estadísticas reales, existe una brecha de madurez natural entre ambas normativas, pero los datos recientes demuestran que el control se está ejecutando en ambas regiones. En la Unión Europea, el enforcement del GDPR es masivo y constante; para principios de 2025, las autoridades europeas habían emitido más de 2,245 multas acumulando aproximadamente 5,650 millones de euros, con un pico de actividad en 2024 que registró más de 600 casos sancionados, incluyendo multas corporativas gigantescas como los 310 millones de euros a LinkedIn.

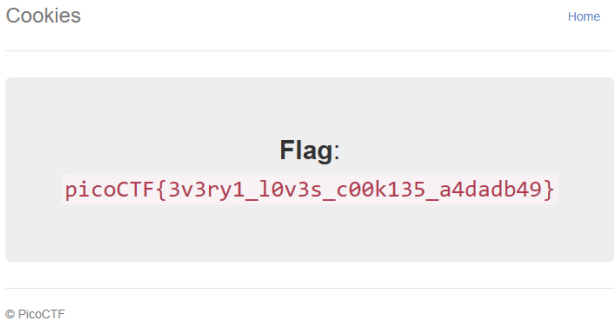
Por su parte, aunque en Ecuador es común la percepción pública de que las leyes tecnológicas carecen de rigor o no se aplican, la evidencia regulatoria actual demuestra lo contrario. Tras superar una extensa fase pedagógica y organizativa, la Superintendencia ecuatoriana entró oficialmente en una etapa de enforcement punitivo a finales de 2025. En diciembre de ese año, la SPDP emitió sus primeras e históricas sanciones administrativas por infracciones graves a la LOPDP. Las organizaciones penalizadas fueron la Liga Profesional de Fútbol (LIGAPRO) con una multa administrativa que superó los $259,000 USD, y la Federación Ecuatoriana de Fútbol (FEF) con más de $194,000 USD. Ambas sanciones se originaron por deficiencias graves en la obtención del consentimiento y la gestión de datos en sus aplicaciones móviles. Este hito, respaldado por resoluciones recientes que exigieron a las empresas el registro obligatorio de sus delegados de Protección de Datos para finales de 2025, proporciona una prueba innegable y documentada de que el régimen sancionatorio en Ecuador está plenamente operativo y castigando el incumplimiento corporativo.

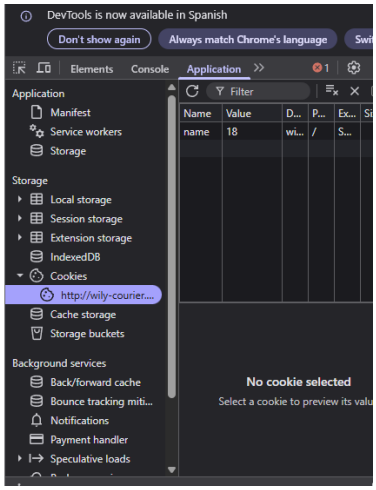
En conclusión, aunque el GDPR europeo y la LOPDP ecuatoriana operan en escalas económicas y niveles de madurez distintos, ambas legislaciones comparten el objetivo fundamental de proteger la privacidad ciudadana a través de la responsabilidad proactiva. Las constantes y millonarias sanciones en la Unión Europea reflejan un ecosistema regulatorio consolidado y altamente riguroso. Por su parte, las recientes e históricas multas impuestas en Ecuador marcan un punto de inflexión crucial en el país: demuestran de forma contundente que la ley ha dejado de ser un marco puramente teórico para convertirse en una realidad jurídica ejecutable, obligando a las organizaciones nacionales a priorizar la seguridad de los datos si desean evitar consecuencias financieras y reputacionales tangibles.

3. Explotación y defensa prácticas:

Inicia sesión en picoCTF y completa dos desafíos de "Explotación web" de tu elección (Recomendado: Cookies, Inspección de HTML o SQLi-Lite).

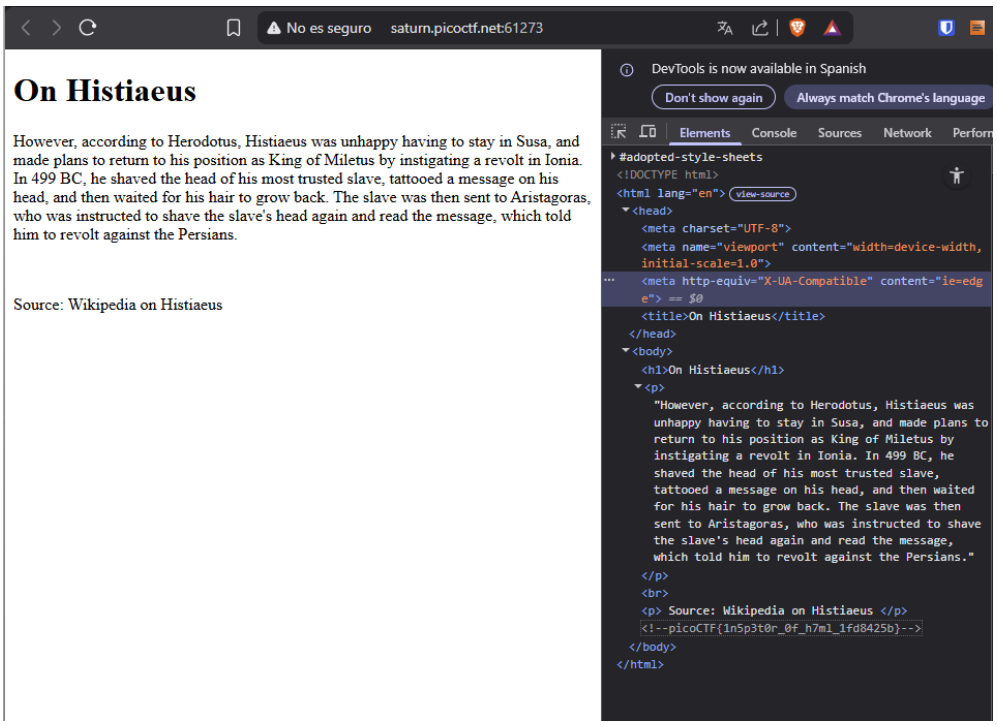
1. Cookies





Explicación: Observamos cómo funciona la página mediante F12 y buscamos fallas que podría tener. La página funciona con una cookie que dice que tipo de galleta es, si vamos variando el valor de la cookie y refrescamos, podemos ver diferentes tipos de galletas en pantalla. En base a esto se fue probando con varios números hasta que salió la clave

2. Inspección de HTML



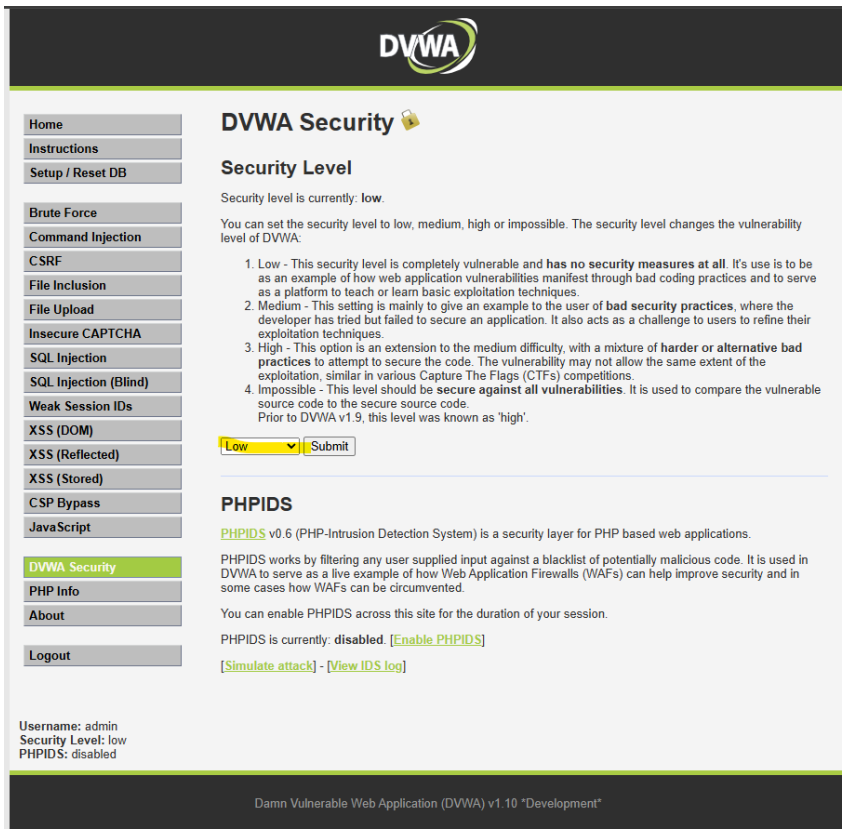
Explicación: Observamos cómo funciona la página mediante F12 y comenzamos a inspeccionar el HTML de la página por algo escondido, no sabemos que puede ser, pero tiene que ir con lo fuera de lo normal. Encontramos un comentario con la clave debajo del todo, como se muestra en la imagen

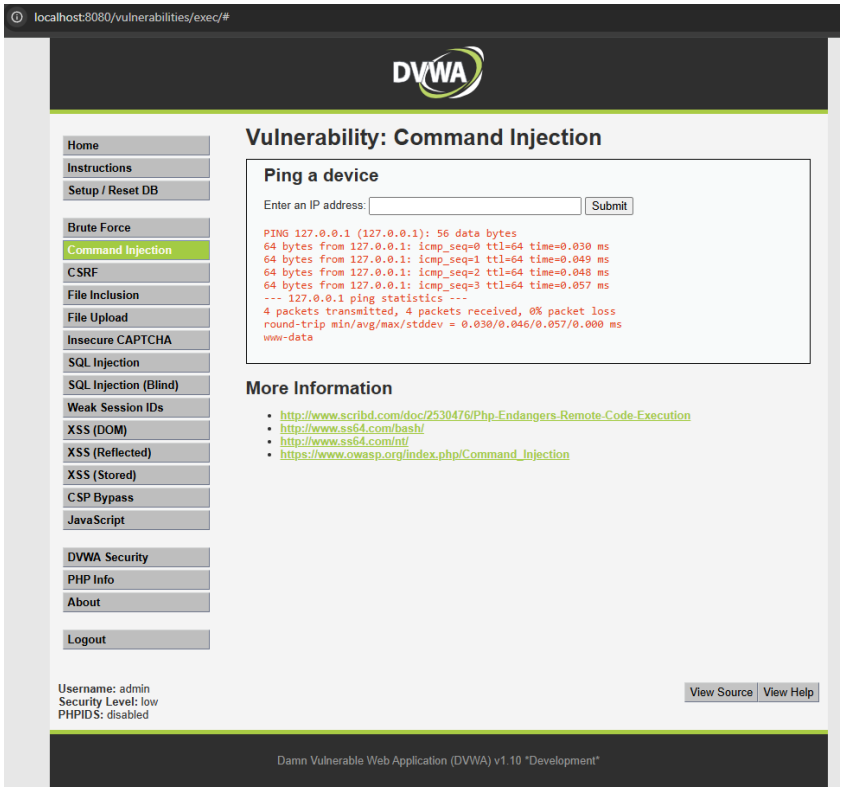
4. Despliegue de WAF (DVWA):

Utilice un entorno local (Docker/VM) para ejecutar la aplicación web vulnerable Damn Vulnerable Web Application (DVWA).

		Name	Container ID	Image	Port(s)
	●	dvwa	9b32b372a942	vulnerables	8080:80
	●	waf	4b8e06a4c1fc	owasp/mo	8000:8080

Ataque: Configure la seguridad de DVWA en "Baja" y realice con éxito una inyección de comandos (por ejemplo, logrando que el servidor devuelva whoami).





Defensa: Implemente un firewall de aplicaciones web (WAF) como ModSecurity (con Nginx/Apache) o una instancia de AWS WAF.

```
SecRule ARGS "([;|])" \
    "id:1000,\
    phase:2,\
    deny,\
    status:403,\
    log,\
    msg:'Command Injection attempt blocked (Semicolon or Pipe detected)'"
```

Validación: Configure una regla para bloquear los puntos y comas (;) o las barras verticales (|) en los argumentos HTTP. Demuestre que el ataque ahora está bloqueado (error 403 Prohibido).

localhost:8000/vulnerabilities/exec/

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

DVWA Security
PHP Info
About

Logout

Vulnerability: Command Injection

Ping a device

Enter an IP address: 127.0.0.1; whoami Submit

More Information

- http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
- http://www.ss64.com/bash/
- http://www.ss64.com/nt/
- https://www.owasp.org/index.php/Command_Injection

Username: admin
Security Level: low
PHPIDS: disabled

View Source View Help

Damn Vulnerable Web Application (DVWA) v1.10 *Development*

localhost:8000/vulnerabilities/exec/#

403 Forbidden

---

nginx

```
"headers":{"Server":"nginx",
"Date":"Sat, 02 May 2026 21:36:57 GMT",
"Content-Length":"146",
"Content-Type":"text/html",
"Access-Control-Allow-Origin":"*",
"Connection":"keep-alive",
"Access-Control-Max-Age":"3600",
"Access-Control-Allow-Methods":"GET, POST, PUT, DELETE, OPTIONS",
"Access-Control-Allow-Headers":"*"}},
"producer":
{"modsecurity":"ModSecurity v3.0.14 (Linux)",
"connector":"ModSecurity-nginx v1.0.4",
"secrules_engine":"Enabled",
"components":["OWASP_CRS/3.3.9\""]},

"messages":[{"message":"Command Injection attempt blocked (Semicolon or Pipe detected)",

"details":{"match":"Matched \"Operator `Rx' with parameter `([;|])' against variable `ARGS:ip'
"reference":"o9,1o9,1v165,17",
"ruleId":"1000",
"file":"/etc/modsecurity.d/owasp-crs/rules/REQUEST-900-CUSTOM.conf",
"lineNumber":"1",
"data":"",
"severity":"0",
"ver":"",
"rev":"",
"tags":["modsecurity"],
"maturity":"0",
"accuracy":"0"}}]}}
```


Este log nos muestra que la defensa fue bien implementada

5. Diseño: La tarea de ingeniería de la privacidad

Estás diseñando una nueva aplicación fintech ecuatoriana llamada "QuitoCash" que permite a los usuarios enviar dinero mediante números de teléfono. La aplicación también utiliza inteligencia artificial para predecir los hábitos de gasto.

Redacta un Aviso de Privacidad: Crea un Aviso de Privacidad de una página para QuitoCash. Debe cumplir explícitamente con el RGPD (para potenciales usuarios europeos) y la LOPDP ecuatoriana.

AVISO DE PRIVACIDAD Y PROTECCIÓN DE DATOS PERSONALES

Última actualización: mayo 2026

En QuitoCash, valoramos su privacidad. Este Aviso de Privacidad explica cómo recopilamos, usamos y protegemos su información personal al utilizar nuestra aplicación de transferencias financieras. Este documento está diseñado para cumplir estrictamente

con la Ley Orgánica de Protección de Datos Personales (LOPDP) de Ecuador y el Reglamento General de Protección de Datos (GDPR) de la Unión Europea.

Bases Legales y Fines del Tratamiento Solo procesamos sus datos personales cuando contamos con una base legal válida:

- **Ejecución de un Contrato:** Tratamos su número de teléfono, nombre completo e historial de transacciones porque son estrictamente necesarios para brindarle el servicio de transferencia de dinero P2P que ha solicitado al aceptar nuestros Términos de Servicio.
- **Interés Legítimo:** Analizamos metadatos básicos de uso de la aplicación para prevenir el fraude y garantizar la seguridad de la red.
- **Consentimiento Expreso:** El uso de sus datos para el análisis predictivo de hábitos de consumo (mediante Inteligencia Artificial) y el envío de comunicaciones de marketing se realiza únicamente si usted nos ha otorgado su consentimiento explícito y afirmativo.

Decisiones Automatizadas y Elaboración de Perfiles (IA de Hábitos de Consumo) QuitoCash ofrece una funcionalidad impulsada por Inteligencia Artificial que analiza su historial de transferencias para predecir sus hábitos de gasto y sugerirle presupuestos personalizados.

- **Su derecho:** En cumplimiento con el Art. 22 del GDPR y el Art. 20 de la LOPDP, usted tiene derecho a no ser objeto de decisiones basadas únicamente en el tratamiento automatizado que produzcan efectos jurídicos o le afecten significativamente.
- **Control:** Esta función es 100% opcional (Opt-in). Si usted activa esta función, tiene derecho a solicitar en cualquier momento la intervención humana para revisar cualquier sugerencia generada por la IA, expresar su punto de vista y revocar su consentimiento desde el menú de "Ajustes de Privacidad" de la aplicación, sin que esto afecte su capacidad para enviar o recibir dinero.

Ejercicio de sus Derechos: Portabilidad y Oposición Usted mantiene el control total sobre su información. A través de la sección "Mis Derechos" en la aplicación o contactando a nuestro delegado de protección de datos (dpo@quitocash.ec), usted puede ejercer:

- **Derecho a la Portabilidad:** Puede solicitar una copia de todo su historial de transacciones y datos de cuenta. Se lo entregaremos en un plazo máximo de 15 días en un formato estructurado, de uso común y lectura mecánica (como un archivo CSV o JSON), permitiéndole transferir su historial financiero a otro banco o plataforma fintech sin obstáculos.
- **Derecho de Oposición:** Usted puede oponerse en cualquier momento a que sus datos sean procesados para fines que no sean estrictamente necesarios para el

funcionamiento de la app (por ejemplo, oponerse a que sus datos se usen para marketing o para entrenar nuestros modelos predictivos de IA). Atenderemos su solicitud de forma inmediata y detendremos dicho procesamiento.

Minimización de datos: Enumere tres puntos de datos específicos que la aplicación podría querer recopilar, pero que no debería recopilar según el principio de minimización de datos para cumplir con la normativa.

1. Extracción completa de la libreta de contactos:

Por qué lo querría la app: Para realizar transferencias mediante números de teléfono sin tenerlo que ingresar manualmente, también para mapear redes sociales de usuarios o hacer campañas de invitación masivas.

Por qué viola la minimización: La aplicación solo necesita acceder al único número de teléfono al que el usuario desea enviar dinero en ese momento. Descargar y almacenar en los servidores de QuitoCash los nombres, correos y notas de todos los contactos del usuario es excesivo e ilegal sin el consentimiento de esos terceros.

2. Historial de navegación web o uso de otras aplicaciones:

Por qué lo querría la app: Para alimentar y hacer más precisa la "IA de predicción de gastos" observando qué tiendas en línea visita el usuario.

Por qué viola la minimización: El servicio financiero central es la transferencia P2P. Monitorear la actividad del dispositivo fuera del entorno aislado de la aplicación QuitoCash es una invasión masiva a la privacidad y va mucho más allá de lo necesario para brindar el servicio financiero u ofrecer resúmenes de gastos basados en las transacciones internas.

3. Almacenamiento centralizado de Datos Biométricos (Rostros y Huellas Dactilares):

Por qué lo querría la app: Para crear un sistema de inicio de sesión propietario o verificar la identidad pidiendo "una selfie" antes de cada transferencia.

Por qué viola la minimización: La biometría está clasificada legalmente como dato sensible. Una app de transferencias P2P no necesita almacenar modelos faciales ni huellas en sus propios servidores. La forma de minimizar este riesgo es delegar la seguridad al sistema operativo del teléfono (usar FaceID o lector de huellas de Android), donde la app de QuitoCash únicamente recibe un código de "aprobado"

o "denegado" del dispositivo, sin tocar, extraer ni almacenar jamás el dato biométrico real del usuario.